

Saptta — Complete Project Guide

One document for architecture, development, deployment, security, user workflows, RBAC, demo, and CI.

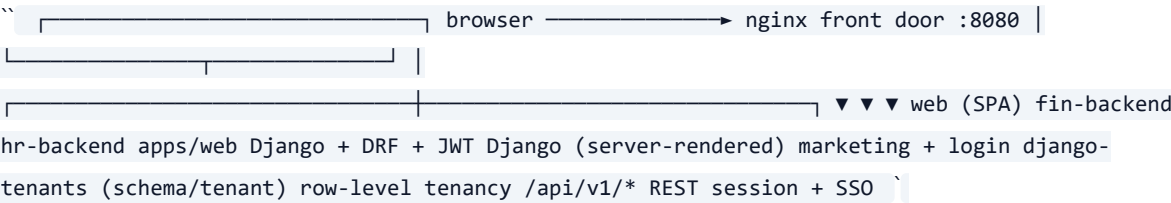
Products: Saptta HR (HRMS) + Saptta Finance — one website, one login, per-product subscriptions.

Markets: India (GST, PF, ESI, TDS) and GCC (Kuwait, UAE, KSA, etc.). **Customer-facing guide (shorter):** open [marketing/collateral/en/saptta-customer-guide.html](#) in Chrome → Print → Save as PDF, or run `node scripts/generate-docs-pdf.mjs` to export both the customer guide and this full project guide as PDFs.

Table of contents

1. [Architecture](#) 2. [Repository layout](#) 3. [Pricing & subscriptions](#) 4. [Local development](#) 5. [Demo credentials & script](#) 6. [User workflows](#) 7. [RBAC & permissions](#) 8. [Security](#) 9. [Production deployment](#) 10. [Go-live checklist](#) 11. [Testing & GitHub CI](#) 12. [Project status & roadmap](#)

1. Architecture



Product	UI	Backend	Auth
Saptta Finance	Ant Design SPA (apps/finance/frontend)	apps/finance/backend	JWT
Saptta HR	Server-rendered Django templates	apps/hr	Session; SSO from platform
Platform	apps/web (marketing + switcher)	FIN public schema	JWT

Why two backends: Finance uses schema-per-tenant (django-tenants); HR uses row-level tenant FK. The website is the single front door for login, billing, and product gating. **SSO:** Platform login → short-lived token → HR session (SSO_SHARED_SECRET must match on both backends). **Auth layers (all users):** 1. **Signup** – email OTP (6-digit code + link); REQUIRE_EMAIL_VERIFICATION=True 2. **Login** – password → TOTP MFA (authenticator app); MFA_REQUIRED=True

2. Repository layout

sapttafinhr/ |— docker-compose.yml # Dev stack |— docker-compose.prod.yml # Production |—

```
deploy/ # nginx, bootstrap scripts | .env.example # Dev secrets template |
.env.prod.example # Production template | scripts/test-all.ps1 # Run all backend tests |
apps/ | web/ # Platform SPA (Vite + React) | finance/ | backend/ # Django REST API |
| frontend/ # Finance tenant SPA | hr/ # HR Django app `
```

3. Pricing & subscriptions

Plan	Products	Price (ex-GST)
Saptta HRMS	HR only (30 employees included)	₹4,999/mo + ₹111/extra employee
Saptta Finance	Finance (unlimited users)	₹4,999/mo
Saptta Complete	HR + Finance + Portal + AI	₹7,999/mo (30 employees · save ₹1,999/mo)

18% GST added at checkout. 14-day free trial. **Product entitlements:** Each tenant has FIN and/or HR entitlements. Middleware blocks access to a product without an active entitlement.

Subscriptions live in FIN apps.saas ; HR mirrors entitlements on the tenant row. **Signup flow:** POST /api/v1/saas/signup/ → provisions workspace (async) → email verify → MFA setup → billing.

4. Local development

Full stack (recommended)

```
` bash cp .env.example .env
```

Generate secrets (examples):

```
python -c "import secrets; print('FIN_SECRET_KEY=' + secrets.token_urlsafe(48))" python -c
"import secrets; print('HR_SECRET_KEY=' + secrets.token_urlsafe(48))" python -c "from
cryptography.fernet import Fernet; print('HR_FIELD_ENCRYPTION_KEY=' +
Fernet.generate_key().decode())" docker compose up --build ` Windows hosts file (add to
C:\Windows\System32\drivers\etc\hosts ): ` 127.0.0.1 localhost acme.localhost hr.localhost `
```

URL	Purpose
http://localhost:8080	Platform (login, marketing, switcher)
http://acme.localhost:8080	Workspace app
http://hr.localhost:8080	HR pages
http://localhost:8080/admin/	FIN Django admin

After first boot: ` bash docker compose exec hr-backend python manage.py seed_permissions docker compose exec hr-backend python manage.py create_tenant \ --name "Acme Pvt Ltd" --subdomain acme

```
--email admin@acme.test --password admin12345`
```

Web SPA only

```
` bash cd apps/web && npm install && npm run dev # http://localhost:5173` Set  
apps/web/.env.local - VITE_PLATFORM_API_BASE_URL , VITE_TENANT_API_BASE_URL .
```

HR backend only (SQLite dev)

```
` powershell cd apps/hr python -m venv .venv && .\.venv\Scripts\activate pip install -r  
requirements.txt $env:DJANGO_SETTINGS_MODULE = "hrms.settings.development" $env:SECRET_KEY =  
"dev-secret" python manage.py migrate python manage.py seed_dummy_login python manage.py  
runserver 127.0.0.1:8001`
```

Finance backend only

Requires PostgreSQL + Redis. See apps/finance/backend - migrate_schemas --shared ,
bootstrap_dev , runserver .

5. Demo credentials & script

Credentials (Docker stack)

Role	URL	Email	Password
Platform owner / HR admin	http://localhost:8080/login	demo@saptta.com	Demo@1234
Super admin	http://localhost:8080/login	sp@saptta.com	Saptta@2026
Finance admin (acme)	http://localhost:8080/login	admin@acme.test	admin12345
HR manager	http://hr.localhost:8080/auth/employee-login/	manager@saptta.com	Demo@1234
HR employee	http://hr.localhost:8080/auth/employee-login/	manju@saptta.com	Employee@1234

Unified login: platform page tries Finance first, then HR staff SSO. **Re-seed demo data:** ` bash
docker compose exec hr-backend python manage.py seed_demo_data --subdomain acme docker compose
exec fin-backend python manage.py bootstrap_dev`

45-minute demo script

1. **Platform (5 min)** – Login as demo@saptta.com → product switcher → open HR. 2. **HR admin (15 min)** – Employees, attendance, leave queue, recruitment, payroll (paid run). 3. **Manager (10 min)** – Employee login manager@saptta.com → approve leave. 4. **Employee (10 min)** – manju@saptta.com → payslip, apply leave. 5. **Finance (5 min)** – Switch to Finance as admin@acme.test .

6. User workflows

6.1 After purchase / signup

1. Customer signs up on platform → workspace provisions in background. 2. Verify email (OTP) → set up MFA → choose plan / billing. 3. First admin email becomes **HR Administrator** for that tenant. 4. Complete **Setup wizard** (/setup/) – company, departments, leave, payroll basics.

6.2 Roles & login URLs

Role	Who	Login
Platform super admin	Saptta ops	http://localhost:8080/login → /superadmin
Company owner	Signup email	Platform login → MFA
HR Administrator	HR head	Platform SSO or HR login
Manager	Team lead	Platform login or /auth/employee-login/
Employee	Staff	/auth/employee-login/

6.3 Onboard an employee

1. **People** → **Employees** → **Add** – official email required. 2. **Profile** → **Create login** → copy **invite link** (7 days, one-time). 3. Employee opens invite → sets password → dashboard. 4. Future logins: employee login URL + work email + password + MFA.

6.4 HR Administrator – daily tasks

Area	Actions
People	CRUD, bulk import, Team Access (roles), org structure
Time	Attendance register, shifts, regularizations
Leave	Types, holidays, balances, approve all
Payroll	Monthly review → create run → recompute → approve → publish
HR Ops	Letters (maker-checker), company vault, recruitment, assets, exits
Reports	MIS exports, monthly pack
Setup	Master data, letter templates, signatories

Payroll month-end: Lock attendance → /payroll/review/ → create run → recompute → approve → publish → bank advice / PF ECR exports.

6.5 Manager

- **My Team** – leave, expenses, regularizations, performance reviews, service requests.

- Must have **employee profile** linked; team = direct reports via **reporting_manager**.

- Approve/reject; HR can override.

6.6 Employee (self-service)

- **My Space** – punch, attendance, apply leave, payslips, expenses, loans, tax declaration, Form 16, assets, help requests, policies.
- **Comp-off**: leave type code **C0** – request credit, then apply C0 leave.

6.7 Service requests

Type	Flow	
Hardware/software	Manager → HR/IT queue	
IT issue	HR queue	
HR/other	HR queue	

Employee tracks under **Help & Requests**; manager under **My Team → Request Approvals**.

6.8 Letters & documents (HR admin)

- **Generate** (`hr_ops.generate_letters`) – draft, submit.
- **Approve** (`hr_ops.approve_letters`) – separate user (maker-checker).
- **Company vault** – legal docs; employees request access, HR approves.
- **Recruitment** → **AI offer** → **HR letter draft** – pipeline integration.

Run after deploy: `python manage.py seed_permissions`

7. RBAC & permissions

Roles

Role	Scope	
HR Admin	Full tenant HRMS	
Manager	Direct reports only	
Employee	Self-service	

Nav uses `user.is_hr_admin` , `user.is_manager` , and linked `employee_profile` .

Access summary

Feature	HR Admin	Manager	Employee	
Employee directory / CRUD	✓	–	–	
Team attendance / leave approve	✓	✓ (reports)	–	
Punch / own attendance	✓*	✓*	✓	
Payroll runs / publish	✓	–	–	
Own payslip	✓*	✓*	✓	
Recruitment / ATS	✓	–	–	
HR letters generate / approve	✓*	–	–	
Company vault manage	✓*	–	request	
Reports (org-wide)	✓	–	–	
AI chat / policy Q&A	✓	✓	✓	

*Requires linked employee profile where marked.

Decorators (`utils/access.py`)

- `@hr_admin_required` – HR admin only
- `@manager_or_hr_required` – manager or HR admin
- `@perm_required("codename")` – granular permissions

8. Security

Control	Status	
JWT + refresh (Finance/platform)	✓	
Email verification OTP on signup	✓	
TOTP MFA on all logins	✓	
Rate limits (login 10/min, signup 5/h)	✓	
Password reset (single-use tokens)	✓	

Control	Status	
Tenant isolation (schema + row-level)	✓	
PII encryption (PAN, Aadhaar, bank – Fernet)	✓	
HTTPS / HSTS / secure cookies (prod)	✓	
SSO shared secret (HR handoff)	✓	
Refresh token blacklist on logout	● Partial	
Full CSP on SPA	● Todo	
Automated backups + Sentry	● Todo	

Required production env vars: `FIN_SECRET_KEY` , `HR_SECRET_KEY` , `HR_FIELD_ENCRYPTION_KEY` , `SSO_SHARED_SECRET` , `REQUIRE_EMAIL_VERIFICATION=True` , `MFA_REQUIRED=True` . **Dev only:** Set `MFA_REQUIRED=False` or `REQUIRE_EMAIL_VERIFICATION=False` to simplify local testing.

9. Production deployment

DNS (wildcard required)

Type	Host	Value	
A	@	VPS IP	
A	app	VPS IP	
A	hr	VPS IP	
A	*	VPS IP (tenant subdomains)	

Configure secrets

```
` bash python deploy/configure_domain.py --domain yourdomain.com
```

Creates .env.prod with strong keys

```
`
```

Deploy

Coolify (recommended): Paste `docker-compose.coolify.yml` , load `.env.prod` , set domains + wildcard SSL. **Manual:** `` bash git clone <repo> /opt/saptta && cd /opt/saptta`

Copy .env.prod, obtain TLS cert (certbot wildcard)

```
docker compose -f docker-compose.prod.yml --env-file .env.prod up -d --build chmod +x
```

```
deploy/bootstrap_deploy.sh ./deploy/bootstrap_deploy.sh --domain yourdomain.com --email
admin@yourdomain.com `
```

Post-deploy migrations

```
` bash docker compose exec fin-backend python manage.py migrate_schemas --shared docker compose
exec fin-backend python manage.py migrate_tenant_schemas docker compose exec hr-backend python
manage.py migrate docker compose exec hr-backend python manage.py seed_permissions `
```

10. Go-live checklist

Infrastructure

- ☐ PostgreSQL + Redis (not SQLite)
- ☐ Celery worker + beat (HR payslip email, reminders)

- ☐ S3/Spaces for media; collectstatic + CDN/WhiteNoise

- ☐ HTTPS, ALLOWED_HOSTS , unique SECRET_KEY s

- ☐ FIELD_ENCRYPTION_KEY set (Fernet)

Email

- ☐ SMTP or SES configured
- ☐ Test payslip, Form 16, invite, verification OTP emails

Security

- ☐ Rotate/remove demo passwords
- ☐ REQUIRE_EMAIL_VERIFICATION=True , SPF/DKIM/DMARC on sending domain
- ☐ python manage.py check --deploy clean (both backends)

Per tenant

- ☐ Admin user + HR admin role
- ☐ Departments, leave types, holidays, salary structures

- ☐ Statutory settings (PF/ESI/TDS or GCC)
- ☐ Letter templates + signatories

Smoke tests

```
` bash python manage.py check_go_live_readiness --strict # HR docker compose exec hr-backend
python manage.py verify_all_features `
```

Post go-live

- ☐ DB + media backups scheduled
- ☐ Sentry / uptime monitoring
- ☐ Share this README (user workflows section) with customer admins

11. Testing & GitHub CI

CI runs on every push/PR to main (`.github/workflows/ci.yml`):

Job	What
web	tsc --noEmit + production build
finance-frontend	tsc + build
fin-backend	manage.py check , migration check, pytest (Postgres service)
hr-backend	manage.py check , migration check, full Django test suite

Run locally

```
` powershell
```

All backend tests (Docker must be running)

```
.\scripts\test-all.ps1
```

With frontend build

```
.\scripts\test-all.ps1 -IncludeBuild
```

HR only (no Docker – SQLite dev settings)

```
cd apps/hr $env:SECRET_KEY="test"; $env:DJANGO_SETTINGS_MODULE="hrms.settings.development"
```

```
python manage.py test --verbosity=1
```

Web

```
cd apps/web && npm run build ` E2E (optional): e2e/ Playwright scripts against :8080 - run with -IncludeE2E` when stack is up.
```

12. Project status & roadmap

Done

- Unified platform login, signup, billing (Razorpay)
- HR + Finance product entitlements
- HR SSO from platform; employee unified login
- Email verification + MFA for all users
- HR: payroll, attendance, leave, recruitment AI, letters maker-checker, company vault, multi-signatory PDFs
- Finance: GST invoicing, ledger, client contracts (SOW), sales CRM lite
- GCC payroll jurisdiction (KW, AE, SA, BH, OM, QA)
- Superadmin console, Arabic RTL basics

In progress / planned

- Full Finance SPA live data on all modules
 - JWT tenant claim + refresh token blacklist
 - eSign integration (DSC / DocuSign)
 - Automated backups, Sentry, full CSP
 - WAF / admin IP allowlisting
-

License

Proprietary — © Sappta Tech Solutions